

Lecture 05

Foundations - Part 01

Cyber Security and Privacy | NPTEL 106106248

Prof. Saji K. Mathew, IIT Madras

Video: <https://www.youtube.com/watch?v=WAlmfXGwhOs>

Study transcript from publicly available YouTube captions. Course content and video rights belong to NPTEL / IIT Madras. For personal study only.

Hello and welcome to the second session of cybersecurity and privacy course. So, in the last class we had a brief introduction about cybersecurity and privacy, actually we were trying to understand what the title means. So, it is like laying the foundation for foundation and today is the foundation for cybersecurity. So, we will dwell on certain fundamental aspects of cybersecurity, predominantly cybersecurity and privacy as a topic, we will do after a few sessions on cybersecurity gets over and you will get to appreciate what is, what are the connections between data privacy and cybersecurity through, of course, through several sessions that follow.

So, essentially cybersecurity as an administrative issue, is what this course is focusing on. So, in administration you need to administrate, you need to manage several resources. So, you have to as managers, you manage human resources, you manage technological resources you manage tangible and intangible resources of a organization. So essentially, we do not look at cyber security as a technological issue alone but we also look at it as a broad or much bigger issue concerning governance and management of organizations.

So what are the frameworks that are available what are the standards that are available for cyber security management in practice is a part of this course as I outlined in the previous session. And we would also be looking at technology in a three dimensional perspective, as I explained in the last class, as technology as a source of threat, technology as an asset to be protected and technology also as a tool or as a firewall for protecting your cyber assets. So there are three aspects to technology in this course. And the cyber security challenges are emerging, we have seen that in the last class.

So, I am going to bring certain diagrams that actually help you understand the concept of cyber security or information security in a holistic way, understanding what are the different dimensions of it. So one such diagram is this and of course the title is information security, As I explained to you in the last class, cyber security and information security are closely related. Information security is a part of cyber security and it is a most important part of cyber security I would say and therefore you can understand it from multiple dimensions. You can see, there are three major dimensions - information security as the main concept or the main central concept, the main concept and then you can see there are three concentric circles, which constitute three dimensions or three constituents of information security which are network security, computer and data security and management of information security.

And in the intersection, you see the intersection, a shaded intersection which actually emerges from the management perspective in terms of color, you can see that but which is central, you know, which is common to all the three. So, in other words, you can see that policy guides,

policy is the reference for security related practice, security related decisions, for example, how much should an organization invest in cyber security? We are going to discuss a case today where there is an organization which is invested as much as Pentagon, invests in security. So huge focus on cybersecurity, that may not be the case with all organizations.

So the policies would differ from organization to organization, depending on the criticality of the cyber assets and other considerations, that organization choose, chooses. So, they make choices on cybersecurity investments. So the policy is the intersection and policy guides decisions as I said, then you see network security and computer and data security. Other way to think about it is, well, this is about in data and information.

So in data and information, there are three aspects, one is data storage, other is data transmission and the third is data processing. So these are the computing elements- data storage devices, data transmission and data processing. So, security pertains to these three aspects of computing. You can see computer and data security involves data, databases and computer means processing.

So the applications that process the data. So that is one aspect, storage and processing and the third aspect is data transmission. You can see network security when data or information is transmitted from node A to node B, there is a chance of data breach or you know unauthorized access to the data and therefore that is another aspect or another aspect of computer security or information security. So data storage, data transmission and data processing - three aspects of computing needs protection and should be secured and that is what is represented in this diagram.

And, well, in order to do that, you need management practices and management policies. There should be human resources, there should be technology for protecting these assets and there should be decisions on, how much to protect and how much to leave, how much to leave - that is also a decision management actually, may not over invest in security, we will see that. So all these are pertaining to the administrative dimension of cyber security. So you can see cyber security is not one - cyber security involves all the three and there is a need for understanding and also practicing it, as an integrated effort to protect cyber assets.

Now, this is a very important aspect of cyber security as a course, any course in cyber security you do, be it a technology course, be it a management course, you will have these three concepts which will be a common fundamental set of three concepts - Confidentiality, Integrity and Availability. So, this is often called the CIA triangle, CIA triangle. So, what is CIA triangle means one way to understand it is, CIA is the purpose of cyber security, what does cyber security do? Cyber security ensures that confidentiality, integrity and availability of information is secured.

So it is like the purpose, what is cyber security's aim to achieve, it aims to achieve confidentiality, integrity and availability of information, information in the cyber world. Well, that is the most dominant or most important concept, the concept, set of concepts that pertain to cyber security. Of course, the cyber world goes beyond information today, so those aspects we will slowly integrate into the lessons that are coming up but at a fundamental level, if you look at the purpose of information security, it is to ensure these three aspects which are

important for computing for it which are important for secured storage processing and transmission of information. So there may be other aspects, other concepts also related to cyber security, for example accountability.

So those are related concepts, we will discuss them one by one. So let us try to understand what each of these concepts are, in some more detail as we go. So I will get into each of these concepts in the coming slides but let us have a holistic understanding of cyber security or information security, I am using it, these two terms synonymously now. So, here is an NSTI SSC security model, also known as McCumber cube or John McCumber is the person, who proposed this cube which makes understanding about cyber security holistic, very holistic and if you look at it closely and if you are in the practice of cyber security, this cube ensures that you do not miss anything.

do not miss anything, you do not miss any aspect of cyber security. There are three dimensions that McCumber cube actually represents in a cubical form, the first dimension is the computing dimension which we discussed, storage processing transmission these are the three roles of computer systems and that is where your information and data reside. So those are the assets and those are the devices which actually are involved in the storage processing and transmission of data. The second dimension is the objective or the purpose of cyber security which is availability integrity and, sorry, confidentiality, integrity and availability.

So when computer systems store, process and transmit data, they should be secure, what does security means - security means confidentiality, integrity and availability. So these three dimensions of computing should be protected with respect to confidentiality integrity and availability. Now how do you do that? How do you actually protect?

There are three methods to ensure cyber security, they are number one, policy, number two, education and number three, technology. These are methods to ensure cyber security in terms of confidentiality, integrity and availability for data and information storage, processing and transmission. So it is very intuitive, the important lesson here is, suppose you look at one cell of this cube, it does not miss, it looks at all the three dimensions for example, there is an application so that is for data processing, look at the center dimension. So this is for this particular cell, you will look at it from three dimensions.

So for example, this is for data processing and integrity of data processing has to be ensured and this integrity has to be ensured with respect to policy, education and technology. So this, the number of cells of course, you can, you know say, so three into three into three, so each cell is holistic and when as my practicing managers, you can actually ask these questions, you know, are all these cells considered in cyber security? Due attention has been paid to all the three dimensions across all the cells. So that is the, that is another fundamental concept or a fundamental framework to understand cyber security - the McCumber cube.

Now, let me also take you through the CIA triangle which we discussed, which I propose as the three objectives or the purpose of cyber security. The first concept is confidentiality. What is confidentiality? Confidential information.

So I have heard in administrative circles, if you want to make something public and make a

gossip out of something, put some document is so called, you know you want to actually leak it out, put it into an envelope, close this and put a heading - confidential and give it to a clerk, that will be the talk of the town the next day. So the moment you say confidential, you become curious. So people are curious to listen to conversations or tap data which is not theirs. There is a human tendency, sometimes it is out of many reasons.

So I can't tell you all the reasons why people want to access others information. There can be malice, there can be evil intentions, there can be fun, there can be, it could be by mistake also. So there could be human errors but it can happen due to several reasons. The purpose of cyber security is to ensure that if person A sends an information to person B and person A wants this to be read only by person B and not by any C, system has to ensure that, this transmission of data from A to B is confidential, that is it is read, only by B and not by C.

And three scholars, of course, they are not scholars, they are also entrepreneurs, you must have heard about this name Rivest, Shamir and Adleman, they actually, we will refer to them later on in encryption techniques, when we discuss in a later class. So they published a paper in 1978 in IBM systems journal where they actually represented confidentiality using the diagram that is given here. Alice is sending a confidential letter or a message to Bob and then there is the evil Eve, actually wanting to intercept or wanting to know what is going on. So that is where, the aspect of confidentiality comes.

A data which is confidential should be read by only the intended recipient not by anybody else and that is what confidentiality is. And you can think of the application of this concept in so many situations or so many contexts in business and in society. For example, who accesses your private information, who has access to your credits or your academic performance. So, the institute can give access to those who can access it and those who should not access it, as those who are not supposed to access it, should not do it.

So the data has to be protected against unauthorized access unauthorized access. And see for example, best example is our Aadhaar database. Aadhaar database is biometric and it is your personal identity. And it is the responsibility of the country to ensure that this is not accessed by people or anyone.

It is my data. So, that is where the privacy aspect comes in. And when I shared it with someone, it should be used by that entity or the data processor only with those for whom I have given permission, I have given consent to share the data. There is always a consent between the data collector or the data processor and the data subject.

And therefore that contract should be maintained and that is what confidentiality is. Confidentiality is the responsibility of the data collector to ensure that data is shared only with the intended recipients and not with unintended recipients. So how do we actually ensure this? So, in order to ensure confidentiality, there is need for information classification.

For example, in an organization there is personal data and there is data about your salaries for example, in a company when you work, And the HR department has to ensure that your salary data is known, can be accessed by maybe certain superiors but not by your peers or your subordinates. There is a policy. So the policy has to be implemented in the database access.

Essentially you are ensuring confidentiality as to who can access and who cannot access.

So therefore information need to be classified. We will discuss information classification later, as to what is confidential and what is not confidential or what is top secret as in the US military. And then documents have to be secured in terms of storage and the security policies has to be applied and people need to be trained and so on. That is the confidentiality aspect of information.

So you will see in systems that ensure confidentiality, when an information passes from Alice to Bob, the jealous Eve may be able to access that data. You may be able to intercept and even if you intercept you cannot actually make out what it is. Caesar cipher, you know, Caesar used to communicate with his commanders through someone. But if someone on the way reads that you do not understand anything.

So that is encryption. We will come to that. The second aspect of cyber security is integrity. What do you mean by integrity when you hear this word what comes to your mind?

Completeness. Yeah, integrity means purity, completeness. Okay. No compromise on the quality.

Yeah it talks about quality. It talks about completeness. It talks about purity. Is that the word you use?

Okay. Alright. Okay. So we refer to people, you know, the so and so person does not have integrity and so and so person high integrity.

So integration, integrity means whole, the full. So if part is missing, somebody is really good in doing job but somebody gets into malpractices. So we say, integrity is questionable. Some aspect is fine but some aspect is missing.

Integrity is that. There is an information that is transmitted from A to B. That is the whole information. At A, it is the whole information but when it reaches B, part of it is missing.

For example, you are giving your CV. You are sharing your CV with placement and you have your complete CV. But somebody is jealous about your CV and removes your work experience. Then, I hope it does not happen, but then information is passed.

CV is passed but integrity is the problem. Part of the data is stolen or missing or somebody actually changes your work experience. Say, you said, 10 years and somebody makes it 2 years. You alter the data.

So you also manipulate it. All that is about the integrity of the data. So when data passes from A to B, the data should reach B intact. We call it intact, without any damage, without any manipulation, without any change and it should be as it is.

That is the integrity aspect of data. And in practical scenarios, for example if you share your data in with your employer and employer does not give you access to your personal data or your professional or your bio data. And suppose you did a certificate program or you updated your, you want to update your CV. But as an employee, they do not give you access to your data.

Then again, it is a matter of integrity. You are not able to update your data. And today, by regulation it is required that when a data, a subject shares the data with a data controller or a data collector, the subject should have access to that data wherever it is stored. I should be able to make changes to that data.

It is my data and I should have access to it. It is one of the privacy rights. It is also about the integrity of the data. The data is incomplete.

And suppose, it can also happen when somebody entered that data into a database, your date of birth is entered wrong. And date of birth matters in employment. Suppose you are born in year 2000, suppose it is entered as 2010, there is a big problem out there. Even one year change can actually affect your promotions and so many things.

So it affects you and you are the affected party, others may not mind. So it is somebody else's problem but user must have access. So it is a problem of data integrity, essentially. So it reflects in so many aspects in organizations, in government and in so many other settings.

So integrity is therefore a very fundamental aspect of information security. Confidentiality and then integrity. Who has access to your data and protecting your data without damage. That is the second aspect.

And the third dimension of cyber security is availability. Well, availability is the other side of confidentiality. Data should not be available to unintended audience. But data should be available, when it is required by the intended party.

When you are in need of information, it should be accessible and available. So it is the other side. It should not be accessed by someone who does not have access rights but it should be accessible and always accessible as per contract, based on the contract. And therefore availability is very critical in certain business context.

Availability of databases. Suppose you are trying to book a ticket, an airline ticket or train ticket in IRCTC. And you try to log in, you log in and you are about to reserve but the database is not available, it is down. And maybe you want to browse and see your past reservations some information you want but the database is not accessible.

You have signed in and therefore you have the privilege to access your data. It's your data, you are not accessing somebody else's. You are within confidentiality but the system should allow you to access your information when you are in need of it. And this is the time for you to make a reservation and the data is not available.

It is a problem of availability. So, in order for computing systems to ensure availability, they need to make provisions for that. Cyber security management requires to ensure data is available to those who are intended recipients of the data. And availability is related to reliability.

If systems are reliable, they will be available. So therefore, reliability engineering, especially in computer systems, ensures the availability of data or databases or access to computing resources using a method known as redundancy. Redundancy is the word. So, how much of redundancy, if one system is down, the processing or access should not stop, should be

available from other systems.

So availability by redundancy. So I am just giving a clue as to how technologically you will ensure availability and availability is also a function of how much. There is a 99.9999 so the number of nines after the decimal point. So, that is a sort of contract also when it comes to B2B in terms of IT contracts, in terms of availability.

So when critical systems run on IT, availability is critical and therefore by contract, by service level agreements, there will be contractual arrangement between parties to ensure availability of systems. And therefore if a client is asking for more availability, you can imagine the service provider has to invest more in redundancy. And therefore, the cost will be higher. So therefore, you can always ask for 100 percent availability but 100 percent comes at a, sometimes an infinite cost.

So, these are concepts that are related to cyber security - confidentiality, integrity and availability and these three terms, even if you forget everything else, should be by heart to you, as students of cyber security. Even if you have woken up in the middle of the night, what is cyber security doing? confidentiality, integrity and availability. So there should be straight recall of these three concepts.

Let me illustrate it with an example. So there is an image of course, what does it take you to, this image, biometric, the yeah, the retinal. So somebody is taking a biometric scan of the eye. It can be different aspects of the eye, we will see that later.